자격증명 흐름과 자원 접근을 연결하는 CloudTrail 침해 조사 그래프

강인석[1], 서장훈[2], 정준식[3], 박기웅†

[1]창원대학교 (학부생), [2]홍익대학교 (학부생)

[3]연세대학교 (학부생), †세종대학교 (교수)

A CloudTrail Incident Investigation Graph Linking Credential Flows and Resource Access

In-Seok Kang[1], Jang-Hoon Seo[2], Jun-Sik Jeong[3], Ki-Woong Park†

[1]Changwon University (Undergraduate student)

[2]Hongik University (Undergraduate student)

[3]Yonsei University (Undergraduate student)

†Sejong University (Professor)

요 약

클라우드 침해 조사에서는 서로 다른 자격증명으로 수행된 호출을 연결하고 각 호출의 대상을 확인해야 하지만, 발급 결과와 후속 호출 주체를 별도로 처리하거나 resources 배열만으로 대상을 추출하면 필요한 연결이 누락될 수 있다. 본 논문은 accessKeyId를 기준으로 발급 대상과 후속 호출 주체를 통합하고 요청·응답 필드에서 대상을 추출하는 CloudTrail 그래프 모델을 제안하며, 워크로드 기반 이동 후보를 관측된 발급과 구분하여 조사 범위를 확장한다. 네 재현 시나리오에서 다중 필드 추출은 정답 자원 식별을 27/32에서 32/32로, 접근 근거 보존을 74/84에서 84/84로 높였고, 공통 조사 전략은 세 시나리오에서 필수 근거를 모두 보존하면서 전체 시간창 대비 반환량을 48.8~94.3% 줄였다.

I. 서론

클라우드 환경의 침해 행위는 하나의 계정이나 자격증명에서 끝나지 않는다. 공격자는 노출된 액세스 키로 역할을 위임받고, 다른 사용자의 키를 생성하거나 워크로드의 임시 자격증명을 사용하여 접근 범위를 넓힌다. 이때 조사자는 개별 API의 실행 여부뿐 아니라 어떤 키에서 다음 키로 활동이 이어졌는지, 각 키가 어떤 자원에 영향을 주었는지를 확인해야 한다. 시간 범위로 로그를 조회하면 필요한 사건과 배경 활동이 함께 반환되므로, 사건 사이의 관계를 근거로 검토 대상을 선택하는 기능이 필요하다.

예를 들어 IAM 사용자에게 새 키가 발급된 뒤 같은 사용자의 S3 삭제가 관측되었더라도, 두 사건이 사용자 노드에 함께 연결되어 있다는 사실만으로 새 키가 삭제에 사용되었다고 판단할 수는 없다.

AWS CloudTrail에는 호출 주체, 요청·응답, 대상 자원, 시각 등의 정보가 기록된다. 역할 위임 응답의 accessKeyId와 후속 호출의 userIdentity.accessKeyId를 대조하면 발급된 키의 후속 사용을 연결할 수 있다. 그러나 발급 결과를 단순 속성으로만 저장하면 이러한 연결을 질의마다 다시 계산해야 한다. 또한 구체적인 대상이 resources 배열에 없더라도 요청 필드의 이름이나 식별자로 확인되는 경우가 있다. 대상을 추출하지 못한 호출은 서비스 수준 활동으로 남아, 자원별 조사에서 해당 접근을 놓칠 수 있다.

본 연구는 세 가지를 제안한다. 첫째, 발급 응답의 키와 후속 호출의 키를 동일 식별자로

† 교신저자: 박기웅(세종대학교 정보보호학과 교수)

이 논문은 2026년도 정부 교육부의 재원으로 한국연구재단 대학기초연구소지원사업(G-LAMP)의 지원(RS-2026-25609336, 20%), 과학기술정보통신부의 재원으로 한국콘텐츠진흥원(KOCCA) 저작권기술 글로벌 인재 양성사업 (Project No.RS-2025-02221620, 50%), 대학ICT연구센터(ITRC) (Project No. IITP-2026-RS-2021-II211816, 10%), 한국연구재단(NRF) 핵심연구사업(Project No. RS-2026-25481431, 20%)의 지원을 받아 수행된 연구임.

통합하여 사용자 단위로 합쳐지던 활동을 키 단위 경로로 복원한다. 둘째, 대상을 resources 배열에 한정하지 않고 요청·응답 필드까지 확장 추출하여, 서비스 수준으로만 남던 호출을 구체적 자원과 연결한다. 셋째, 로그에 남지 않는 자격증명 이동은 워크로드 근거를 갖는 후보로 관측된 발급과 구분해 표현한다. 이를 바탕으로 상류 발급 계보와 하류 자원 접근을 함께 조회하는 공통 조사 전략을 구성하고, 근거 보존과 검토 대상 축소로 평가한다.

II. 관련 연구

SLEUTH[1]은 호스트 감사 로그의 의존 관계를 활용하여 공격 시나리오를 재구성하고, ORTHRUS[2]는 탐지 결과에서 공격의 원인과 영향을 확인하는 분석가의 부담에 주목하여 귀속 분석에 필요한 결과의 품질을 강조한다. 본 연구는 관계를 통한 사건 재구성과 검토 대상 선택이라는 관점을 공유하되, 호스트 프로세스가 아니라 CloudTrail의 자격증명 발급과 자원 접근을 연결 대상으로 삼는다는 점에서 다르다.

AWS 지침[3]은 신원·출처 정보를 대조하여 탈취된 임시 자격증명의 후속 활동을 추적한다. 본 연구는 조사자가 질의마다 반복해야 하는 이 대조 작업을 근거가 명시된 그래프 관계로 구성한다는 점에서 다르다.

III. 제안 모델과 조사 방법

3.1 자격증명 식별과 발급 대상의 주체 통합

그래프의 노드는 자격증명, 신원, 워크로드 및 자원으로 구성한다. 호출 주체에 accessKeyId가 있으면 이를 자격증명 노드의 식별자로 사용하고, 사용자나 역할의 ARN은 신원 정보로 구분한다. 같은 IAM 사용자에 속한 키라도 식별자가 다르면 별도 노드로 유지하므로, 여러 키의 활동이 사용자 단위로 합쳐지는 것을 피할 수 있다. 키 식별자가 없고 invokedBy가 있는 호출은 해당 서비스 노드를 주체로 둔다. 자원은 ARN 또는 서비스별 식별 정보를 바탕으로 구성한 ID로 통합한다.

API 호출은 주체와 대상 사이의 이벤트 간선(BASE_EVENT)으로 표현하며, eventID와 API·시각·성패 등 원본 속성을 보존한다. 한 호출에 여러 대상이 있으면 간선을 각각 생성하되 eventID는 같으므로, 이벤트를 집계할 때는 eventID를 중복 제거한다.

발급 응답에 새 accessKeyId가 있으면 호출 키에서 발급된 키로 OBTAINS 간선을 만들고, 그 키가 이후 호출의 주체로 나타나면 같은 노드를 재사용하므로 발급과 후속 접근을 하나의 경로로 조회할 수 있다. 이벤트 간선이 호출 한 건에 대응하는 것과 달리, 문맥 관계는 반복 관측되는 귀속 사실이며 호출 신원과 sessionIssuer에서 ISSUES를, inScopeOf의 credentialsIssuedTo에서 RUNS_ON을 얻는다. 문맥 관계는 근거 수와 관측 구간을 함께 보존하되 경로 탐색에서는 순회하지 않으므로, 신원을 경유해 무관한 키가 이어지지 않는다. 추론 관계인 CAN_OBTAIN은 관측된 간선이 아니라 문맥과 행위를 결합해 만든 후보로, 3.3절에서 다룬다.

표 1. 제안 모델의 주요 관계와 구분

관계	구분	출발 → 도착
ACCESS 등	이벤트	자격증명 → 자원
OBTAINS	이벤트	자격증명 → 자격증명
ISSUES	문맥	신원 → 자격증명
RUNS_ON	문맥	자격증명 → 워크로드
CAN_OBTAIN	추론	자격증명 → 자격증명

3.2 다중 필드 대상 추출

대상 추출은 먼저 resources 배열의 ARN을 읽고, 요청·응답 및 serviceEventDetails에서 지원하는 식별 필드를 추가로 검사한다. ARN이나 AWS 식별자 패턴뿐 아니라 서비스별 이름 필드를 이용하며, 이름만 존재하면 이벤트의 서비스·계정·리전과 필드 의미를 함께 사용하여 대상 ID를 구성한다. 필드명·문맥 규칙으로 대상 유형을 정하며, 대상을 찾지 못하면 서비스 수준으로 표현한다.

예를 들어 StopLogging의 requestParameters.name은 트레일, ModifySnapshotAttribute의 snapshotId는 스냅샷을 가리킨다. 이 값을 추출하면 호출 키에서 구체적인 대상으로 향하는 접근 간선을 만들 수 있다. 자원 노드가 다른 이벤트로 이미 존재하더라도, 그 호출의 필드에서 대상을 뽑지 못하면 누가 언제 그 자원에 접근했는지는 남지 않는다. 따라서 대상 노드의 존재와 호출별 접근 연결을 함께 보존하는 것이 중요하다.

3.3 워크로드 기반 이동 후보

CloudTrail의 발급 응답만으로 모든 자격증명 획득을 연결할 수는 없다. 예를 들어 IMDS에서 가져온 키의 획득 과정은 해당 API 로그에 직접 남지 않는다. 이를 보완하기 위해 표 1의 RUNS_ON 문맥 관계를 이동 후보의 근거로 활용한다.

성공으로 기록된 주체 a의 워크로드 w 대상 쓰기·발급 호출과 RUNS_ON(b,w)를 결합하면 CAN_OBTAIN(a,b) 후보를 만든다. 자기 연결

과 동일 워크로드에 귀속된 키 사이의 후보는 제외한다. 후보에는 경유 워크로드, 근거 수, 최초 시각 및 두 키의 출처 IP(sourceIPAddress) 집합 중복 여부를 저장한다. 이는 직접 관측된 발급 사실이 아니라 추가 확인할 조사 단서다.

후보 확장은 집계값만으로 연결하지 않고, 선택 시간창에서 a의 성공한 SendCommand 또는 SendSSHPublicKey와 b의 이후 성공·대상 특정 사용이 같은 출처 IP에서 관측될 때만 후보를 채택한다. 제어 시각과 후속 사용 시각을 각각 보존하여 다음 연결은 후속 사용 이후부터 탐색하므로, 후보와 그 원본 근거를 함께 제시한다.

3.4 관계 기반 공통 조사 전략

3.1~3.3의 관계를 이용하면 조사자는 공격 유형별 질의를 따로 만들지 않고, 하나의 시작 이벤트와 시간 범위만으로 상류의 발급 계보와 하류의 자원 접근을 함께 조회할 수 있다. 발급이 로그에 남지 않은 구간은 CAN_OBTAIN 후보를 포함할지 선택하여 조사 범위를 조절한다. 이 전략의 구체적 절차와 결과는 4.4절에서 다룬다.

IV. 실험 및 평가

4.1 데이터와 실험 구성

자격증명 연쇄와 대상 접근을 평가하기 위해 AWS 환경에서 공격·배경 활동을 수행하고 네 시나리오의 로그를 수집하였다. n1은 워크로드 자격증명 획득 이후 키 발급·로깅 중지·객체 삭제, n2는 워크로드 자격증명 획득 이후 시크릿 접근·스냅샷 공유·플로우로그 삭제를 포함한다. n3는 페더레이션 로그인과 사용자 자격증명 변경·키 사용, n4는 역할 위임과 키 발급 연쇄다. 이벤트 수는 각각 129, 165, 138, 140개이며, 사례별 최초부터 최후 이벤트까지 전체 수집 시간창을 사용하였다. 공통 조사 전략은 제안 모델이 생성한 CSV 그래프에서 Python으로 실행하였으며, 보고하는 수치는 그래프 엔진의 처리 성능이 아니라 이 전략의 근거 선택 결과다.

4.2 정답 근거의 정의

실행 단계와 알려진 호출 키·대상으로 조사 질문별 필수 근거를 정하고, eventID·API·시각을 원본 CloudTrail과 대조하였다. 사례별 필수 근거 수는 표 3의 분모와 같으며, 정찰과 발급 준비 등은 문맥으로 구분하고 정답 집합은 질의 결과 선택에 사용하지 않는다. 두 실험은 목적이 달라 정답 범위가 다르다. 4.3절은 구체적 자원 접근만을, 4.4절은 로그인·신원 확인까지 포함한 근거를 정답으로 두므로 같은 사례라도 두 표의 분모가 다르다. 다만 평가에 사용한 로그는 공개 침해 사례가 아니라 저자가 직접 구성·실행한 네 시나리오에서 수집한 것이고 정답 집합도 그 실행 기록으로 정의하였으므로, 배경 활동의 규모와 분포가 실제 운영 환경과 달라 보고 수치를 그대로 일반화하기는 어렵다.

4.3 대상 추출 범위의 효과

같은 원본 로그에서 대상 추출 범위만 바꿨을 때 조사에 필요한 자원과 접근 근거가 얼마나 확보되는지 보기 위한 실험이다. 기준 구성(resources 배열만 사용, 이하 R-전용)은 일반 대상 추출을 resources 배열로 제한하고, 확장 구성(이하 다중 필드)은 요청·응답 등의 지원 필드를 추가로 검사한다. 두 구성에서 호출 주체 식별, OBTAINS, 신원·워크로드 문맥 등 다른 기능은 동일하게 유지한다. 정답은 필수 연결 중 OBTAINS를 제외한 구체적 ARN 대상 접근(IAM 사용자·역할 포함, 서비스 대표 노드 제외)이며, 자원 식별은 해당 ID 노드의 존재, 접근 근거는 (호출 키, 대상 ID, eventID) 튜플의 존재로 판정한다.

표 2. 대상 추출 범위에 따른 정답 자원 및 접근 근거 보존

사례	자원(R-전용)	자원(다중필드)	접근(R-전용)	접근(다중필드)
n1	2/3	3/3	52/54	54/54
n2	21/23	23/23	20/24	24/24
n3	1/3	3/3	0/3	3/3
n4	3/3	3/3	2/3	3/3
합계	27/32	32/32	74/84	84/84

표 2에서 다중 필드 구성이 추가 확보한 10개 접근은 모두 해당 이벤트의 resources 배열이 비어 있거나 없었으며, 요청 필드의 원본 값을 확인하여 대상 ID와 대조하였다. 특히 n4는 R-전용 구성에서도 정답 자원 3개가 모두 존재했지만 신뢰정책 변경과 대상 역할 사이의 접근이 빠져 2/3이었고, 다중 필드 구성은 그 연결까지 보존하였다. 이는 단순히 자원 노드를 많이 만드는 것보다, 각 원본 호출을 올바른 대상과 연결하는 기능이 조사에 중요함을 보여준다.

4.4 근거 보존과 검토 대상 선택

조사자가 하나의 사건에서 출발해 자격증명 연쇄와 자원 접근을 재구성할 때, 3.4절의 공통 조사 전략(이하 제안 전략)이 필수 근거를 모두 보존하면서 검토할 이벤트를 얼마나 줄이는지 확인하는 실험이다. 조사 시작점은 n1·n2의

최초 SendCommand, n3의 GetFederationToken, n4의 신뢰정책 변경이며 후속 API·자원에 추가 제한은 두지 않았다. 제안 전략은 구체적으로 시작 이벤트의 호출 키에서 들어오는 OBTAINS를 시간 역순으로, 나가는 OBTAINS를 시간순으로 따라가며 각 키에 도달한 이후의 접근을 함께 반환하고, 지나온 키는 다시 방문하지 않는다. 본 실험에서는 CAN_OBTAIN 후보를 포함하는 모드로 고정하였으며, 비교 대상은 같은 시간창의 원본 이벤트를 모두 반환하는 시간창 검색이다.

표 3의 연결 보존은 관계 종류와 출발·도착 ID, eventID가 모두 일치하는 필수 간선 수를 전체 필수 수로 나눈 값이다. eventID만 맞으면 되는 이벤트 단위 판정보다 엄격하여, 올바른 이벤트라도 잘못된 키·대상에 연결하면 정답으로 세지 않는다. 시간창 반환과 제안 반환은 각 전략이 반환한 고유 eventID 수이고, CAN_OBTAIN 후보 간선은 연결 수에 합산하지 않는다. 연결 보존이 1이고 시간순 조건을 충족하면 설명 완성으로 판정하며, 완성된 경우에만 시간창 대비 반환량 감소 비율을 축소율로 보고한다.

표 3. 공통 조사 전략의 필수 근거 보존과 반환량

사례	연결 보존	시간창 반환	제안 반환	축소율
n1	55/55	129	66	48.8%
n2	24/24	165	31	81.2%
n3	5/9	138	5	—
n4	6/6	140	8	94.3%

n1·n2·n4는 필수 연결을 모두 보존하고 시간순 조건을 충족하였다. n1은 삭제 관련 기록 52건을 유지하면서 129개 중 66개, n2는 시크릿 접근 20건과 후속 행위를 포함하여 165개 중 31개를 반환하였다. n4는 필수 6개와 사용자 생성·정책 부착 문맥 2개를 반환하였다. 축소율은 시간창의 폭과 배경 활동량에 영향을 받으므로 절대 반환량과 함께 해석한다.

n3는 구체적 대상이 없는 서비스 수준 행위가 현재 전략의 탐색 범위 밖이므로 필수 9개 중 5개만 반환하여 축소율을 보고하지 않았다.

관측 발급만 사용하면 n1·n2의 연결 보존은 각각 1/55, 2/24였으나, 후보 포함 모드에서는 55/55, 24/24로 증가하였다. n3·n4에서는 두 모드의 결과가 같았다.

V. 결론

본 논문은 발급 대상과 후속 호출 주체를 자격증명 식별자로 통합하고, 다중 필드에서 대상 자원을 추출하는 CloudTrail 조사 그래프를 제안하였다. 대상 추출 비교에서 기본 구성에 누락된 자원 5개와 원본 접근 10개를 확보하였으며, 공통 조사 전략은 세 시나리오에서 필수 근거를 유지하면서 전체 시간창 대비 48.8~94.3% 적은 이벤트를 반환하였다. 워크로드 이동 후보는 관측 발급만으로 확보하지 못한 후속 근거의 조사에 기여하였다.

워크로드 이동 후보는 추가 확인이 필요한 조사 단서이며 자격증명 획득 사실의 확정이 아니다. 분석가의 실제 조사 시간은 측정하지 않았다. 다중 필드 추출의 기여는 요청 필드에서 확인하였으며, 응답 필드의 기여는 분리하여 측정하지 않았다. 향후에는 로그인·신원 확인 행위를 조사 범위에 포함하고, 다양한 정상 운영 활동과 사건에서 후보 근거 및 질의 결과를 평가할 계획이다.

[ACKNOWLEDGEMENT]

본 논문은 과학기술정보통신부 및 한국정보보호산업협회의 융합보안 인력양성사업(ICT융합산업보안)으로부터 지원받은 연구임.

[참고문헌]

[1] M.N. Hossain, S.M. Milajerdi, J. Wang, B. Eshete, R. Gjomemo, R. Sekar, S. Stoller, and V.N. Venkatakrishnan, “SLEUTH: Real-time attack scenario reconstruction from COTS audit data,” Proceedings of the 26th USENIX Security Symposium, pp. 487–504, Aug. 2017.

[2] B. Jiang, T. Bilot, N. El Madhoun, K. Al Agha, A. Zouaoui, S. Iqbal, X. Han, and T. Pasquier, “ORTHRUS: Achieving high quality of attribution in provenance-based intrusion detection systems,” Proceedings of the 34th USENIX Security Symposium, pp. 7173–7192, Aug. 2025.

[3] O. Diaz, J. Paz, and S. de Vera, “Incident response guide for AWS CloudTrail investigations – Part 2,” AWS Security Blog, Sep. 2026. https://aws.amazon.com/blogs/security/incident-response-guide-for-aws-cloudtrail-investigations-part-2/